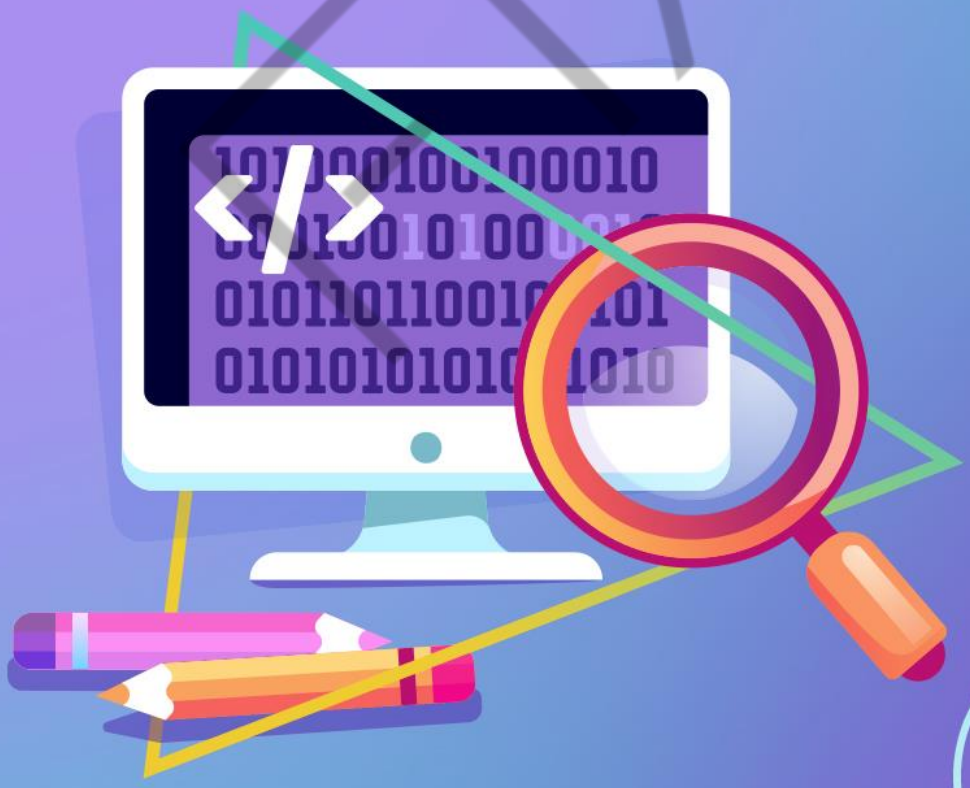
FIAP ON

GESTÃO DE RISCOS E VULNERABILIDADES

Gestão de VULNERABILIDADES

CLEITON ALVES DA SILVA



02

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

LISTA DE FIGURAS

Figura 2.1 – Site Common Vulnerabilities and Exposures (CVE) 7
Figura 2.2 – Site da calculadora *Common Vulnerability Scoring System Version 3.0* 9
Figura 2.3 – Dados da empresa Equifax 12
Figura 2.4 – Resultado da pesquisa por vulnerabilidade em sistemas 13
Figura 2.5 – CVEs publicadas por ano 16
Figura 2.6 – Ciclo de vida da gestão de vulnerabilidade 20

FIAP

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

LISTA DE TABELAS

Tabela 2.1 - Níveis de severidade e os intervalos base de pontuação de acordo com o CVSS 9

FIAP

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

SUMÁRIO

2 GESTÃO DE VULNERABILIDADES 5
2.1 Quem está vulnerável? 5
2.2 Quem está em risco? 6
2.3 Métricas de vulnerabilidades 8
2.3.1 Classificações de gravidade da vulnerabilidade do NVD 8
2.4 De onde vêm as vulnerabilidades? 10
2.5 Um pouco mais sobre o que causar vulnerabilidades 11
2.6 Tendências em ataques cibernéticos 11
2.7 Gestão de vulnerabilidades 14
2.8 Elementos para uma gestão de vulnerabilidades 15
2.8.1 Escopo da vulnerabilidade 16
2.8.2 Verificação de vulnerabilidades 17
2.9 Gestão de vulnerabilidade na prática? 18
2.10 Ciclo de vida da gestão de vulnerabilidades 19
2.11 Qual é o processo da gestão de vulnerabilidades? 19
2.12 Como melhorar a estratégia da gestão de vulnerabilidades 21
2.13 Avaliação de vulnerabilidade e teste de penetração 22
REFERÊNCIAS 25

FIAP

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

2 GESTÃO DE VULNERABILIDADES

Na área de segurança cibernética, uma vulnerabilidade é uma fraqueza que pode ser explorada por um ataque cibernético, a fim de obter acesso não autorizado ou executar ações também não autorizadas em um sistema de computador. O ***Technical Guide to Information Security Testing and Assessment (NIST)*** define vulnerabilidade como uma fraqueza em um sistema de informações, procedimentos de segurança do sistema, controles internos ou implementação que podem ser explorados ou acionados por uma fonte de ameaça. Na ISO 27005, a definição está relacionada a uma fragilidade de um ativo ou grupo de ativos que pode ser explorada por uma ou mais ameaças.

De forma geral, os sistemas de computadores, em princípio, são vulneráveis, visto o modo como são elaborados, pois podem apresentar falhas no design, na implementação ou em sua operação, e o gerenciamento desses sistemas pode ser explorado para violar a política de segurança.

As vulnerabilidades podem permitir que os invasores executem códigos, acessem a memória de um sistema, instalem *malwares* (*software* malicioso) e roubem, destruam ou modifiquem dados confidenciais.

Para explorar uma vulnerabilidade, um invasor deverá conectar-se ao sistema do computador e, então, utilizar entre as diversas técnicas ou ferramentas disponíveis um método para explorar as vulnerabilidades existentes. Por exemplo, entre essas variedades de métodos, estão disponíveis *SQL injection*, *buffer overflows*, *cross-site scripting* (XSS) e kits de exploração de código aberto que procuram vulnerabilidades conhecidas e pontos fracos de segurança em aplicativos da Web.

A existência de um erro, design ou implementação pode levar a um evento indesejável inesperado que possivelmente possa comprometer a segurança ambiente, seja o sistema, rede ou as aplicações envolvidas.

2.1 Quem está vulnerável?

Para que você possa responder a essa pergunta, é preciso compreender a necessidade da gestão de vulnerabilidades em um ambiente tecnológico.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

Para um cibercriminoso, as vulnerabilidades existentes em nossos sistemas podem ser direcionadas à exploração, o que resulta em acesso não autorizado à rede e aos ativos de alto valor. Uma vez que o invasor acessa o ambiente, a intenção pode ser procurar informações pessoais, dados de cartão de crédito, contas bancárias, além de segredos comerciais e propriedade intelectual, de forma geral, a busca será por algo que possam negociar. Além disso, o computador explorado agora é um ponto de partida para novos ataques à sua rede e pode se tornar parte de uma plataforma que poderá ser utilizado para atacar a rede de outras organizações.

Pesquisadores de segurança da informação estão continuamente descobrindo falhas em *softwares*, configurações defeituosas de aplicativos e equipamentos de TI. Vale lembrar que os softwares são desenvolvidos por humanos e, muitas vezes, não são testados exaustivamente em busca de falhas, consequentemente, novas vulnerabilidades aparecem diariamente.

Qualquer que seja sua fonte, as vulnerabilidades não desaparecem sozinhas, você deve pressupor que detecção, remoção e controle requerem gerenciamento de vulnerabilidades e o uso contínuo de ferramentas de segurança especializadas, juntamente com um fluxo de trabalho que incentive identificar e eliminar potenciais riscos ou eventos que prejudiquem a segurança da informação.

2.2 Quem está em risco?

Todos os sistemas com conexão à Internet, sejam aqueles disponíveis nas organizações ou em casa, estão em risco devido às possíveis vulnerabilidades existentes. Você pode perguntar: O tamanho da organização influencia em algo? A reposta geralmente é que, para uma empresa nacional, multinacional ou um governo, não faz diferença, você sempre estará em risco.

O principal desafio, para todas as empresas, é manter o acesso a algumas informações de forma segura com clientes, fornecedores e parceiros de negócios em todo o mundo. Mas, infelizmente, tornar essas informações altamente disponíveis e de forma segura é um trabalho muito árduo, com a quantidade de *malwares*, como vírus, que constantemente ameaçam o roubo de informações e a interrupção das operações comerciais.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

A taxa constante de novas vulnerabilidades descobertas a cada dia e a velocidade com que novas explorações são criadas tornam esse desafio ainda mais acentuado. Principalmente, quando os sistemas dos computadores estão executando sem atualizações de segurança, eles são os alvos preferidos em busca de vulnerabilidades e uma grande variedade de explorações.

Você pode visitar o site na Internet: <http://cve.mitre.org/index.html>, e visualizar algumas vulnerabilidades conhecidas de segurança cibernética. O ***Common Vulnerabilities and Exposures (CVE)*** permite a realização de pesquisas visando ao conhecimento de fragilidades em sistemas operacionais e aplicações, cada uma contendo um número de identificação, uma descrição e pelo menos uma referência pública. As entradas CVE são usadas em vários produtos e serviços de segurança cibernética de todo o mundo.

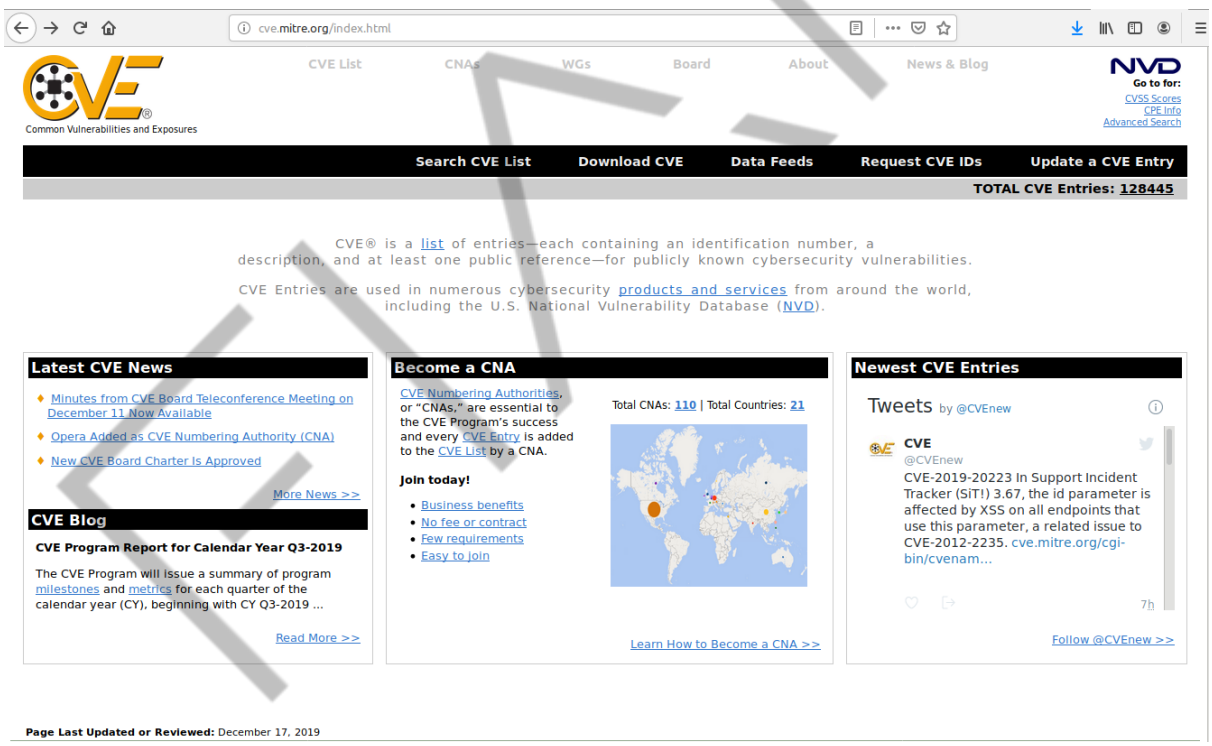


Figura 2.1 – Site Common Vulnerabilities and Exposures (CVE)
Fonte: Elaborado pelo autor (2020)

Adiante, você obterá mais detalhes de como lidar como os esses identificadores.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

2.3 Métricas de vulnerabilidades

O ***Common Vulnerability Scoring System (CVSS)*** é um *framework* para comunicar e divulgar as características e a gravidade das vulnerabilidades relacionadas ao *software*. O CVSS consiste em três grupos de métricas: base, temporal e ambiental. As métricas de base produzem uma pontuação que varia de 0 a 10, que podem ser modificadas com a pontuação das métricas temporal e ambiental.

Uma pontuação CVSS é bem adequada, como um sistema de medição padrão para indústrias, organizações e governos que precisam de pontuações de severidade de vulnerabilidades precisas e consistentes.

O ***National Vulnerability Database (NVD)*** fornece pontuações CVSS para quase todas as vulnerabilidades conhecidas e afirma que dois usos comuns são (NVD, 2020):

- utilizados para calcular a gravidade das vulnerabilidades descobertas nos sistemas;
- como um fator na priorização das atividades de correção de vulnerabilidades.

O ***National Vulnerability Database (NVD)*** fornece pontuações CVSS para quase todas as vulnerabilidades conhecidas. O NVD disponibiliza uma calculadora CVSS para o CVSS versão 2 e versão 3 para permitir que você adicione dados de pontuação temporal e ambiental. O CVSS pertence e é gerenciado pela FIRST.Org, Inc., uma organização sem fins lucrativos sediada nos EUA, cuja missão é ajudar as equipes de resposta a incidentes de segurança de computadores em todo o mundo.

2.3.1 Classificações de gravidade da vulnerabilidade do NVD

O NVD fornece classificações qualitativas de gravidade/severidade de "Baixa", "Média" e "Alta" para os intervalos de pontuação base do CVSS v2.0, além das classificações de gravidade do CVSS v3.0, conforme definidas na especificação do CVSS v3.0.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

Observe que a Tabela “Níveis de severidade e os intervalos base de pontuação de acordo com o CVSS” apresenta os níveis de gravidade/severidade e os intervalos base de pontuação de acordo com a classificação das versões 2.0 e 3.0.

Severidade	Intervalo de pontuação	Severidade	Intervalo de pontuação
		Nenhum	0.0
Baixa	0.0-3.9	Baixa	0.1-3.9
Média	Classificação CVSS v2.0	Classificação CVSS v3.0	4.0-6.9
Alta	7.0-10.0	Alta	7.0-8.9
		Crítica	9.0-10.0

Tabela 2.1 - Níveis de severidade e os intervalos base de pontuação de acordo com o CVSS
Fonte: Elaborado pelo autor (2020)

Você pode conhecer melhor o CVSS acessando o site: <https://www.first.org/cvss/> e, além disso, também pode conhecer mais detalhes sobre a calculadora do CVSS 3.0 no mesmo site, por meio do link: <https://www.first.org/cvss/calculator/3.0>, conforme apresentado na figura: “Site da calculadora *Common Vulnerability Scoring System Version 3.0*”.

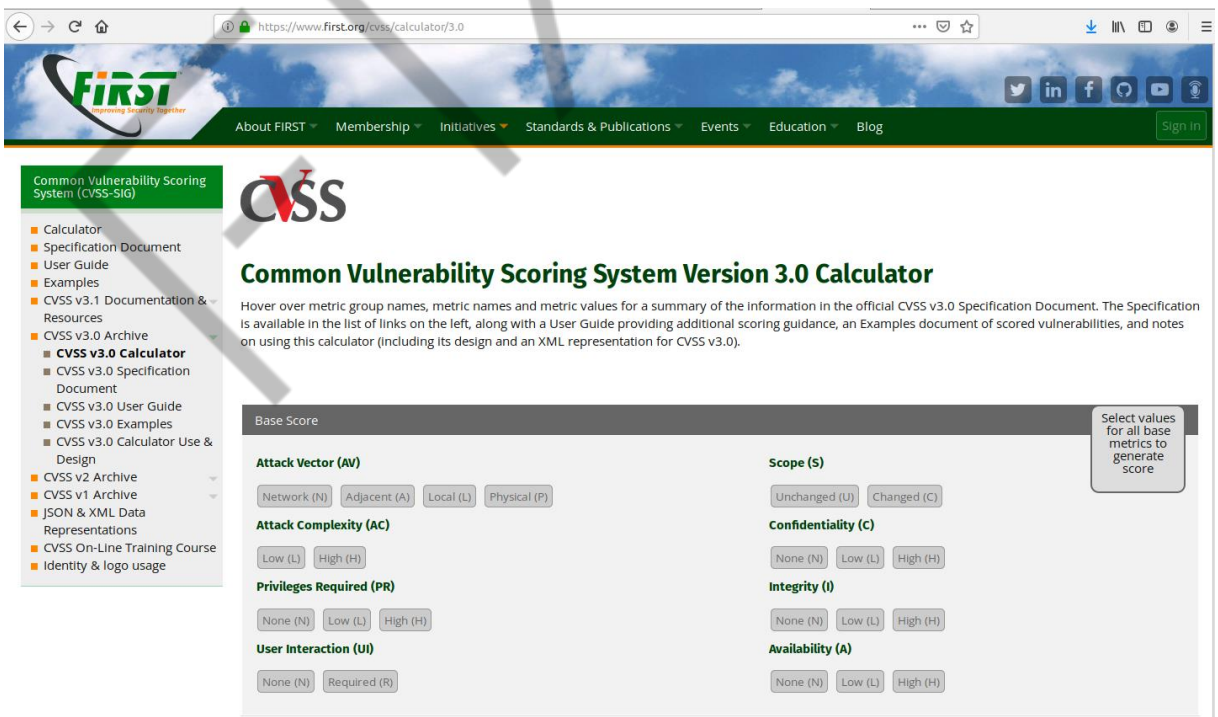


Figura 2.2 – Site da calculadora *Common Vulnerability Scoring System Version 3.0*
Fonte: Elaborado pelo autor (2020)

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

2.4 De onde vêm as vulnerabilidades?

Erros de programação (os famosos *bugs*) geram a maioria das vulnerabilidades nos *softwares*. Um erro que acontece na área de gerenciamento de memória de programas é deixar os blocos de dados usados, mesmo depois de serem declarados livres por outras partes dos programas. Quando esse erro de programação é encontrado pelos invasores, eles geralmente podem explorá-lo e obter controle sobre o computador.

Os cientistas da computação estimam que a cada mil linhas de código de *software* em produtos de software bem gerenciados haja cerca de um *bug*. Um sistema operacional como o Windows 7, por exemplo, possui 40 milhões de linhas de código, um aplicativo do Microsoft Office, entre 30 e 50 milhões, e navegadores populares da Internet, entre cinco e 10 milhões (KANDEK, 2015). É por isso que você constantemente recebe anúncios regulares de atualizações com correções e soluções alternativas relacionadas às vulnerabilidades.

Os invasores não desenvolvem explorações para todas as vulnerabilidades que são publicadas, mas examinam constantemente vulnerabilidades críticas em pacotes de software amplamente instalados. Para você ter uma ideia do alcance dos invasores, considere que algumas empresas que desenvolvem software determinam que até 25% das vulnerabilidades que publicam são exploradas nos primeiros 30 dias após a publicação (KANDEK, 2015).

As fraquezas dos sistemas são erros de programação, visto que, os aplicativos contêm vulnerabilidades expostas por configurações incorretas. Imagine, por exemplo, a configuração inadequada de aplicativos de segurança como um *firewall*, permitindo aos invasores passarem pelas regras de segurança e acessarem as informações em uma rede. Se é que foram configuradas corretamente.

A melhor maneira de combater essas ameaças é identificar e eliminar rapidamente todas as vulnerabilidades, e isso você deve fazer de forma contínua. A exploração de vulnerabilidades via Internet é um enorme problema que requer controle e gerenciamento proativo imediato. É por isso que as empresas precisam usar a gestão de vulnerabilidades para detectar e eliminar proativamente as vulnerabilidades, a fim de reduzir o risco geral à segurança e impedir a exposição.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

2.5 Um pouco mais sobre o que causar vulnerabilidades

Além das causas apontadas anteriormente, existem muitas outras origens de vulnerabilidades, incluindo:

- **Complexidade:** sistemas complexos aumentam a probabilidade de uma falha, configuração incorreta ou acesso não intencional.
- **Familiaridade:** código, *software*, sistemas operacionais e hardware comuns aumentam a probabilidade de um invasor encontrar ou ter informações sobre vulnerabilidades conhecidas.
- **Conectividade:** quanto mais conectado um dispositivo, maior o tempo e a chance de explorar uma vulnerabilidade.
- **Gerenciamento inadequado de senhas:** senhas fracas podem ser quebradas com força bruta e a reutilização de senhas pode resultar em muitas violações de dados.
- **Falhas no sistema operacional:** como qualquer software, os sistemas operacionais podem conter falhas.
- **Entrada não verificada do usuário:** se o seu site ou software assumir que todas as entradas são seguras, ele poderá executar comandos SQL não intencionais.
- **Pessoas:** A engenharia social é uma das maiores ameaças para a maioria das organizações. Além da falta de conhecimento e treinamento em segurança da informação.

2.6 Tendências em ataques cibernéticos

As divulgações constantes de violação de dados nas notícias documentaram a exposição não autorizada de milhões de registros confidenciais de consumidores em todo o mundo. O dano resultante à reputação de uma organização violada pode ser significativo, fazendo com que os clientes levem seus negócios para outro lugar.

Vale lembrar o ataque à empresa Equifax, a multinacional de crédito que confirmou ter sofrido um ataque cibernético, o que resultou no acesso ilimitado aos

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

dados de 143 milhões de consumidores norte-americanos (Nomes e Número de previdência social e Carteira de motorista). Horas após a divulgação, houve queda de 12,38% no valor das ações.

Figura 2.3 – Dados da empresa Equifax
Fonte: Elaborado pelo autor (2020)

A consequência desse dano é uma prova adequada do motivo pelo qual as organizações devem fazer mais para proteger seus sistemas e redes contra os ataques cibernéticos. Observe, ainda, que a Figura “Resultado da pesquisa por vulnerabilidade em sistemas” apresenta o resultado de uma pesquisa na Internet sobre as Notícias relacionadas as “vulnerabilidades em sistemas”.

Se você parar por um instante esta leitura e fizer a mesma pesquisa, provavelmente observará que serão inúmeras as ocorrências.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

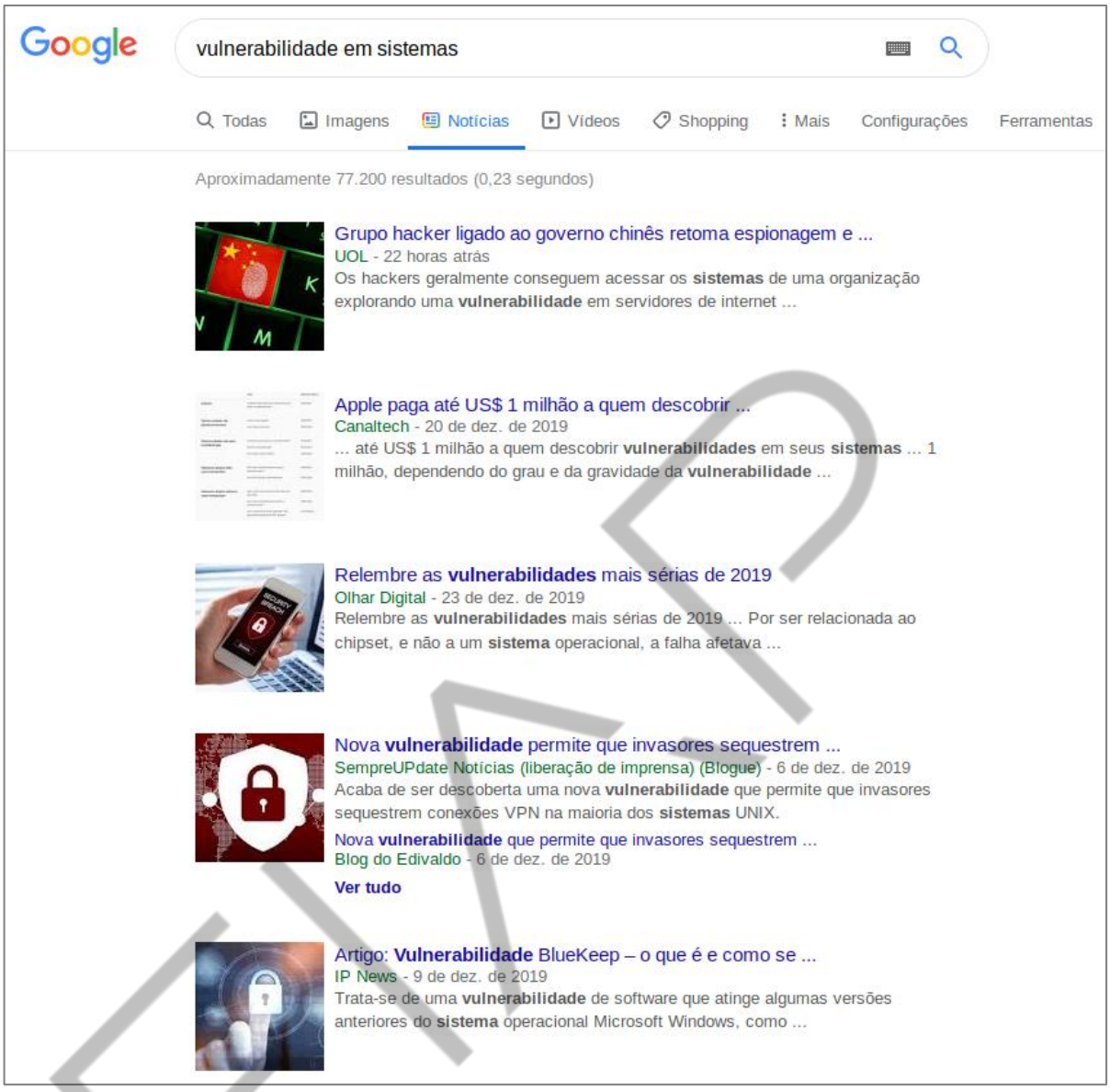


Figura 2.4 – Resultado da pesquisa por vulnerabilidade em sistemas
Fonte: Elaborado pelo autor (2020)

Em uma estratégia de segurança cibernética, os *endpoints* (*laptops* e estações de trabalho) são considerados "elos mais fracos" e é neles que oitenta por cento dos ataques cibernéticos acontecem atualmente.

Jim Souders, chefe executivo da Adaptiva, considera que o cibercrime deve custar US $ 6 trilhões anuais até 2021 (SOUDERS, 2019), e que garantir a segurança nos *endpoints* se torna uma prioridade absoluta. É por isso que você deve prestar mais atenção à rápida evolução em que se encontra o gerenciamento de vulnerabilidades. As empresas modernas entendem que precisam impulsionar a conformidade para reduzir os riscos e precisam fazê-lo de uma maneira decididamente mais eficiente.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

2.7 Gestão de vulnerabilidades

Em um cenário tradicional, no qual a gestão de vulnerabilidades está presente, a equipe de Segurança da Informação (SI) deve encontrar o maior número possível de vulnerabilidades e corrigi-las ou indicar a solução para a equipe de Tecnologia da Informação (TI). Esse é um processo muito trabalhoso, em que as respectivas equipes pesquisam vulnerabilidades, aplicam patches, realizam testes de penetração e avaliações de vulnerabilidades e muito mais. Embora o processo de gestão de vulnerabilidades seja impossível sem a assistência de software, os modelos tradicionais ainda dependem muito da inteligência humana para tomar uma ampla gama de decisões e tomar ações.

A equipe TI deve determinar quais alterações, se houver alguma, precisam ser feitas e elas precisam executar atividades de conformidade de rotina que exigem uma parte significativa do tempo. Infelizmente, você deve saber que tempo disponível é algo que as empresas simplesmente não têm. Algumas empresas contam com equipes de TI muito reduzidas, devido ao orçamento e às restrições de recursos disponíveis e, diante desse cenário, a gestão de vulnerabilidades pode sofrer devido à falta de profissionais capacitados.

À medida que a tecnologia avança, a capacidade de automatizar cada vez mais componentes do processo de gestão de vulnerabilidades se torna essencial, e um dos aspectos mais subestimados da gestão moderna de vulnerabilidades é a flexibilidade que pode acompanhar as soluções automatizadas. Embora alguns produtos ou ferramentas apresentem opções pré-configuradas para ajudar as equipes de TI em relação a alguns dos processos onerosos durante o desenvolvimento de verificações ou ações de correção de vulnerabilidades, a próxima geração de ferramentas dará um passo adiante. Além de automatizar uma grande porcentagem dos processos de gestão de vulnerabilidades, as equipes terão a opção de criar verificações personalizadas de integridade, conformidade e segurança, além de ações de correção automatizada.

Você aprenderá mais sobre ferramentas relacionadas ao processo de gestão de vulnerabilidades mais adiante.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

2.8 Elementos para uma gestão de vulnerabilidades

No início, as ameaças eram apenas os “hackers”, visto o método que utilizavam para acessar a rede por meio de portas abertas no firewall ou explorar vulnerabilidades conhecidas em sistemas acessíveis pela Internet, como servidores da web e de e-mail. Dessa forma, você, basicamente, protegia sua rede implementando regras em um *firewall* e, claro, que tinha que testá-lo periodicamente.

O cenário de ameaças atual oferece aos invasores uma seleção muito maior de pontos de ataque na forma de portas de firewall abertas para o tráfego comercial, servidores da Web ou de outros servidores atrás do firewall, com todos os aplicativos em execução internamente na rede, incluindo os *endpoints* e servidores. Isso oferece aos cibercriminosos diversos métodos de ataque para encontrar vulnerabilidades em sua rede.

Os invasores ainda têm aplicativos que eliminam toda a dificuldade de invadir sua rede, e essas aplicações podem ser usadas para executar ataques automatizados de alta velocidade que eram impensáveis há alguns anos. Computadores comprometidos em todo o mundo podem ser agrupados logicamente nos chamados "botnets" e, com o uso de software de comando e controle, podem realizar ataques coordenados contra os maiores e mais sofisticados sistemas.

Ataques direcionados a sistemas internos são mais lucrativos financeiramente e mais eficazes que ataques externos. SPAM, *phishing*, engenharia social, *malware*, cavalos de Tróia, dispositivos de mídia portáteis e outros métodos são comumente usados para comprometer sistemas, subvertendo completamente as soluções de segurança tradicionais, como firewalls, sistemas de detecção de intrusão e até verificações de vulnerabilidades externas

Um aspecto positivo é que muitos desses métodos de ataque dependem do sistema ser vulnerável de alguma forma, e muitos ataques estão procurando pontos fracos ou configurações incorretas no navegador e nas aplicações web. Identificar e corrigir essas vulnerabilidades se torna um dos desafios que você pode enfrentar para ficar à frente dos cibercriminosos.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

2.8.1 Escopo da vulnerabilidade

Primeiro, você precisa entender o escopo do problema de vulnerabilidade e, para isso, é preciso ter ciência de que existem tipos diferentes de vulnerabilidades conhecidas, aquelas mais famosas, mas precisa se concentrar nas variedades e saber que existem muitas outras para se descobrir. Posso garantir, claro que consultei antes, que existem mais de 120.000 vulnerabilidades, e se você quiser verificar, consulte o site do CVE para saber a quantidade de vulnerabilidades descobertas até o momento. A Figura “CVEs publicadas por ano” exibe a quantidade de vulnerabilidades publicadas desde o início dos registros de 1999.

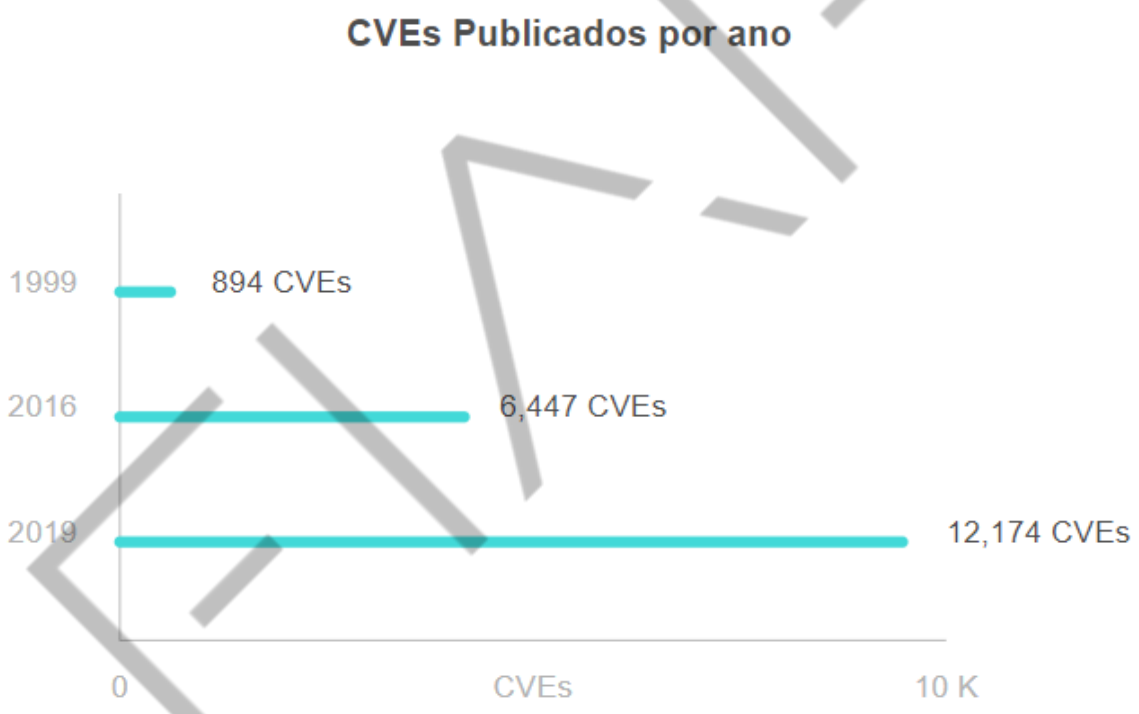


Figura 2.5 – CVEs publicadas por ano
Fonte: Elaborado pelo autor (2020)

Realmente, há um número crescente em relação às vulnerabilidades registradas, e é isso que as pessoas chamam de vulnerabilidades conhecidas, porém, não podemos deixar de acreditar que existam as vulnerabilidades desconhecidas. Depois que uma vulnerabilidade é encontrada, os scripts de vulnerabilidade podem ser escritos para procurá-las e identificá-las.

Nem todas essas vulnerabilidades afetam todos os sistemas diariamente, mas com o passar do tempo, é provável que muitas delas sejam identificadas em cada um

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

dos seus sistemas. As questões com as quais você deve se preocupar e estar ciente incluem:

- **Sob o RADAR:** às vezes, os criminosos descobrem vulnerabilidades em uma rede, sistema ou aplicativo e as usam para comprometer sua rede. Essas são difíceis de detectar, dado que os sistemas projetados para detectar ataques conhecidos, como um serviço, uma detecção de intrusão não terá assinaturas para procurar e identificar esses ataques em suas redes.
- ***0-Day Exploration*:** outras vezes, alguém anunciará ou liberará informações sobre uma vulnerabilidade sem haver uma correção ou patch para mitigar essa fraqueza. Essas são conhecidas como vulnerabilidades de dia zero. Os criminosos podem explorar a vulnerabilidade antes que patches e correções estejam disponíveis. Geralmente, existem maneiras de impedir o ataque, se conhecido, antes do lançamento do *patch*, mas geralmente é difícil acompanhar o grande volume de vulnerabilidades.

De acordo com o grande número de vulnerabilidades existentes, algumas das etapas a seguir são necessárias tomar para proteger sua organização.

2.8.2 Verificação de vulnerabilidades

Uma verificação de vulnerabilidade é o processo usado para identificar, nos sistemas operacionais, serviços e aplicativos, se há fragilidades que possam ser exploradas. Esse processo é feito principalmente usando ferramentas que mantêm um banco de dados de scripts, que podem ser utilizados para detectar vulnerabilidades conhecidas nos sistemas.

O resultado é um relatório que enumera quais sistemas são vulneráveis, de que maneira eles são vulneráveis e a criticidade da vulnerabilidade encontrada. Esses relatórios de verificação são conhecidos como relatórios de avaliação de vulnerabilidades. De acordo com o ambiente, as verificações executadas em dispositivos acessíveis pela Internet são conhecidas como Avaliações de Vulnerabilidade Externa, enquanto as verificações executadas em sistemas na parte interna da rede são conhecidas como Avaliações de Vulnerabilidade Interna.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

As **Avaliações de Vulnerabilidades Externas** sempre foram consideradas as mais críticas, porque os dispositivos acessíveis à Internet, como *firewalls*, servidores Web, servidores de e-mail e outros estão mais expostos a invasores. Esses sistemas, normalmente, expõem as portas e os serviços em que a maioria das vulnerabilidades pode ser descoberta, como a porta 80, na qual os sites estão hospedados. É claro que existem inúmeras outras portas e serviços que possuem vulnerabilidades conhecidas, muitas das quais expostas à Internet.

Os invasores também desenvolveram métodos para comprometer as vulnerabilidades existentes nos sistemas que residem na rede interna, esses ataques geralmente são uma combinação de um tipo de engenharia social e *malware*. Os processos relacionados devem fazer parte da Avaliações de Vulnerabilidade Interna.

2.9 Gestão de vulnerabilidade na prática?

A gestão de vulnerabilidades está relacionada diretamente com identificar, mitigar e reparar vulnerabilidades em sistemas e redes. As organizações usam a gestão de vulnerabilidades como um processo proativo para melhorar a segurança em aplicativos, software e redes de computadores. Quando bem implementada, a gestão de vulnerabilidades pode ajudar uma organização a ficar significativamente mais segura contra violações de segurança e roubo de dados.

Da mesma forma, o gerenciamento de patches é a implantação de um patch de computação para reparar uma vulnerabilidade em um sistema. Um patch é um conjunto de alterações feitas em um programa projetado para atualizar, corrigir ou melhorar sua funcionalidade. O manuseio adequado desse processo é crucial, pois mais de 80% das violações de segurança são resultado de um gerenciamento inadequado de patches (SMITH, 2017)

Antes de abordar as especificidades da gestão de vulnerabilidades e das práticas recomendadas, é importante entender as distinções entre vulnerabilidades e riscos à segurança, pois os termos geralmente são conflitantes. Um risco em segurança da informação descreve o potencial de perda, dano ou destruição de um ativo. Uma vulnerabilidade descreve uma fraqueza específica que um invasor pode explorar para executar ações não autorizadas em um sistema de computador. Embora

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

os riscos levem em consideração as vulnerabilidades e as avaliem com ameaças e ativos, elas não são a mesma coisa. Você deve compreender essa diferença, pois é o primeiro passo para melhorar as práticas de segurança.

2.10 Ciclo de vida da gestão de vulnerabilidades

O ciclo de vida da gestão de vulnerabilidades descreve as etapas específicas que precisam ser tratadas continuamente no processo da gestão de vulnerabilidades. As especificidades variam de organização para organização, mas existem vários elementos que serão relevantes e úteis para a maioria delas:

- **Descobrir:** saiba onde estão os pontos fracos da rede.
- **Priorizar:** categorize ativos em grupos e atribua um valor com base em quão críticos eles são para as operações do seu ambiente computacional.
- **Avaliar:** avalie a disposição e a capacidade do seu ambiente em assumir riscos com base na criticidade de ativos e nas ameaças em potencial.
- **Relatório:** avalie o nível de risco associado aos ativos do seu ambiente, de acordo com as políticas de segurança de suas organizações.
- **Corrigir:** priorize e corrija vulnerabilidades de acordo com o risco atribuído.
- **Verificar:** verifique se as ameaças foram eliminadas.

Se você abordar todas essas etapas em seu processo de gestão de vulnerabilidades, terá as melhores chances de manter os sistemas e as redes protegidos.

2.11 Qual é o processo da gestão de vulnerabilidades?

O processo da gestão de vulnerabilidades leva em consideração o ciclo de vida de gerenciamento, como mostrado na Figura “Ciclo de vida da gestão de vulnerabilidade” e mencionado acima, na qual pode ser utilizado como um guia de ação. Aqui são apresentados alguns processos principais que você pode implementar para melhorar a segurança de vulnerabilidades e manter seus sistemas e redes protegidos:

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

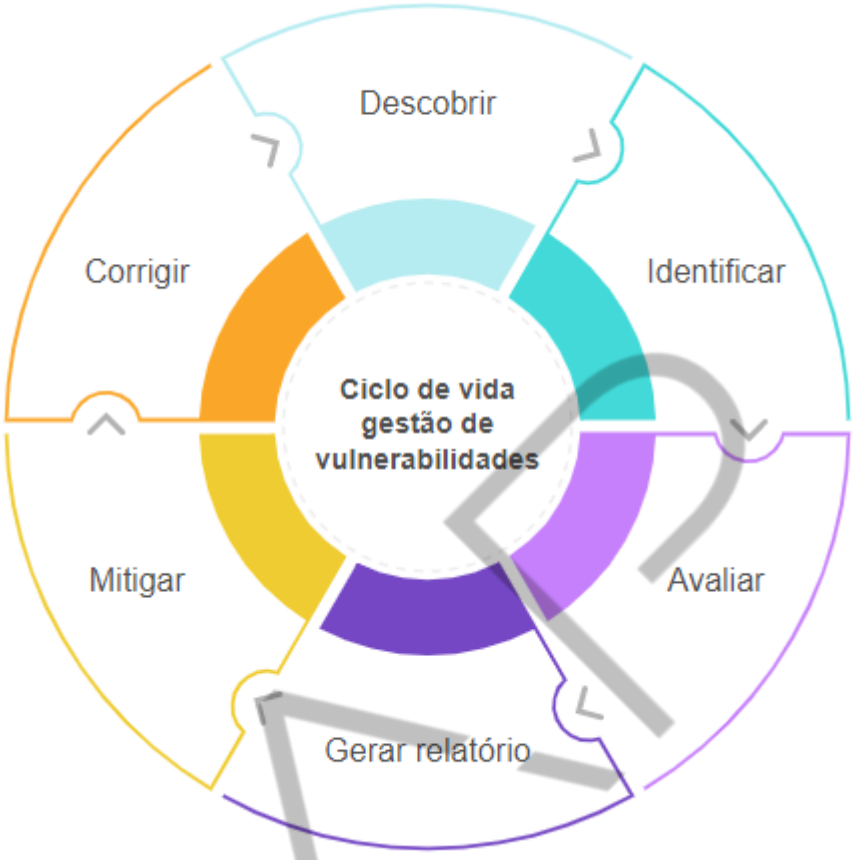


Figura 2.6 – Ciclo de vida da gestão de vulnerabilidade
Fonte: Elaborado pelo autor (2020)

1. Descobrir vulnerabilidades: verificações de rede, logs de firewall e testes de penetração são ferramentas importantes da gestão de vulnerabilidades para localizar quaisquer pontos fracos que as redes e sistemas do seu ambiente possam ter; essas ferramentas devem ser usadas regularmente; e considere automatizá-las, se possível.

2. Identificar as vulnerabilidades: usando os dados gerados nos logs, testes e varreduras, você pode localizar qualquer anomalia que possa sugerir uma má ação nas redes e sistemas do seu ambiente (ataques de *malware*, atividades suspeitas etc.).

3. Avaliar as vulnerabilidades: determine se as vulnerabilidades identificadas têm o potencial de serem exploradas em servidores, aplicativos, redes ou outros sistemas.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

4. Gerar relatório (reportar): avalie o nível de risco associado aos ativos do seu ambiente computacional de acordo com as políticas de segurança de suas organizações

5. Mitigar as vulnerabilidades: se um *patch* não puder ser emitido rapidamente ou se não houver uma solução de *patch* para uma determinada vulnerabilidade, você precisará criar soluções de espaço reservado para o ambiente em que se encontram seus ativos. Você pode considerar colocar a parte afetada de um sistema *offline* ou colocar em quarentena um ataque.

6. Corrigir as vulnerabilidades: depois de identificar uma vulnerabilidade e avaliar se ela representa um risco, é hora de corrigir. Geralmente, os patches podem ser obtidos ou adquiridos dos fornecedores do software ou hardware afetado. Se possível, tente agendar um horário para a instalação do patch para que não interfira na atividade do usuário.

2.12 Como melhorar a estratégia da gestão de vulnerabilidades

Todas as ações propostas pelos processos da gestão de vulnerabilidades abordam as preocupações e as etapas definidas pelo modelo de ciclo de vida, mas elas não são as únicas ações que os profissionais de segurança da informação podem executar para melhorar seus serviços. Aqui estão algumas práticas recomendadas adicionais para que você implemente quando necessário.

1) Invista nos serviços de testes de penetração o máximo possível para melhorar a descoberta de pontos fracos nas redes de seu ambiente. Essa é a primeira etapa do modelo de ciclo de vida e, se não for bem-sucedida, limitará severamente o sucesso de seus esforços no processo da gestão de vulnerabilidades. Técnicas de penetração são usadas para avaliar a segurança de uma rede de maneira controlada, mas não se preocupe se nesse momento você não conhece todas essas técnicas, pois elas ainda serão apresentadas durante o curso.

2) Uma das melhores maneiras de priorizar e avaliar os ativos dos seus ambientes é inventariar seus sistemas. Essa medida ajudar a identificar tecnologias implantadas que podem estar colocando seus sistemas em risco. Uma das coisas que

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

você pode fazer para contribuir nessa etapa é classificar seus ativos de rede por plataforma. Também deve identificar quais ferramentas defensivas já estão em vigor.

Empregar um serviço de gestão de vulnerabilidades seria discutível sem oferecer também serviço de patch suficiente. Afinal, o patch é, geralmente, a única maneira de corrigir as ameaças identificadas às vulnerabilidades dos ativos, e uma maneira de implementar é considerar o uso de uma solução automatizada de gerenciamento de patches, que poderá ajudar a ficar em dia com as atualizações contínuas.

Sem um programa de gestão de vulnerabilidades, a segurança dos sistemas e rede ficará suscetível a possíveis ameaças. Embora a introdução de um novo processo de gestão de vulnerabilidades na organização possa ser desafiadora, é mais fácil seguir de perto o modelo do ciclo de vida, pois ele o ajudará na implementação d**as diretrizes de serviço eficaz.**

Vamos finalizar este capítulo apresentando a diferença entre avaliação de vulnerabilidade e teste de penetração.

2.13 Avaliação de vulnerabilidade e teste de penetração

Muitos profissionais de segurança da informação estão familiarizados com os termos "avaliação de vulnerabilidade" e "teste de penetração" (*pentest*, de forma abreviada). Infelizmente, em muitos casos, esses dois termos são usados incorretamente e, como já comentado, vamos esclarecer as diferenças entre avaliação de vulnerabilidade e teste de penetração. Pretendemos demonstrar que ambos são componentes integrais de um programa completo de gestão de vulnerabilidades, além de quando e onde cada um é mais apropriado.

Vamos relembrar os conceitos: uma avaliação de vulnerabilidade é o processo de localizar e medir a gravidade das vulnerabilidades em um sistema. As avaliações de vulnerabilidade produzem relatórios das vulnerabilidades dos sistemas, geralmente priorizadas pela gravidade e/ou criticidade dos negócios.

As avaliações de vulnerabilidade geralmente envolvem o uso de ferramentas de teste automatizadas, como scanners de segurança na *web* e na rede, cujos resultados são normalmente avaliados e encaminhados às equipes de

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

desenvolvimento e operações. Em outras palavras, as avaliações de vulnerabilidade envolvem uma avaliação profunda de uma postura de segurança projetada para descobrir pontos fracos e recomendar a correção ou mitigação apropriada para remover ou reduzir os riscos.

Por outro lado, o teste de penetração é, tipicamente, um exercício orientado a objetivos. Um *pentest* tem menos a ver com a descoberta de vulnerabilidades e é mais focado em simular um ataque da vida real, em testar defesas e em traçar caminhos que um invasor real poderia seguir para atingir uma meta do mundo real. Em outras palavras, um teste de penetração é geralmente sobre como um invasor é capaz de violar defesas e menos sobre vulnerabilidades específicas.

O teste de penetração, como a avaliação de vulnerabilidade, também normalmente envolve o uso de scanners de vulnerabilidade automatizados e outras ferramentas manuais de teste para encontrar vulnerabilidades em aplicativos da web e infraestrutura de rede. Até esse ponto, a diferença fundamental entre a avaliação da vulnerabilidade e o teste de penetração é que o primeiro é orientado por relatórios e o último, orientado a objetivos.

Portanto, considerando que a avaliação da vulnerabilidade e o teste de penetração geralmente utilizam muitas das mesmas ferramentas e técnicas, por qual metodologia você deve optar, quando e por quê?

Como o teste de penetração testa as defesas de segurança em um caminho em direção a uma meta, geralmente é mais útil quando o nível de maturidade de segurança do alvo é alto, ou seja, quando se acredita que as defesas de segurança do alvo são fortes. O teste de penetração é uma metodologia eficaz para testar afirmações sobre as defesas dos sistemas com objetivos específicos em mente. Isso significa que o teste de penetração é mais adequado em situações em que a profundidade se deseja alcançar em um sistema é preferida.

A avaliação de vulnerabilidade, por outro lado, é especialmente adequada em situações em que existem problemas de segurança conhecidos ou quando uma organização que não possui a segurança necessária gostaria de começar. Como alternativa, a avaliação de vulnerabilidade é uma metodologia ideal para organizações que possuem uma maturidade de segurança média a alta e gostariam de manter sua postura de segurança por meio de uma avaliação contínua da vulnerabilidade. A

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

avaliação de vulnerabilidade é, portanto, uma abordagem focada em fornecer às organizações uma lista de vulnerabilidades (relatórios) que precisam ser corrigidas, sem avaliar metas ou cenários específicos de ataques.

FIAP

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

REFERÊNCIAS

ABNT. **NBR ISO/IEC 27005:2008:** Tecnologia da Informação – Técnicas de Segurança – Gestão de Riscos de Segurança da Informação. Rio de Janeiro: ABNT, 2019.

CONTINUOUS Vulnerability Managament. 2021. Disponível em: <https://www.cisecurity.org/controls/continuous-vulnerability-management/>. Acesso em: 26 fev. 2021.

KANDEK, W. **Top 10 Vulnerabilities.** 2015. Disponível em: <https://blog.qualys.com/laws-of-vulnerabilities/2015/03/03/top-10-vulnerabilities-february-2015>. Acesso em: 26 fev. 2021.

SOUDERS, J. **Flexibility in Vulnerability Management:** Why it's Essential. 2019. Disponível em: <https://www.cyberdefensemagazine.com/flexibility-in-vulnerability/>. Acesso em: 26 fev. 2021.

MUSCAT, I. **The difference between Vulnerability Assessment and Penetration Testing**. 2017. Disponível em: <https://www.acunetix.com/blog/articles/difference-vulnerability-assessment-penetration-testing/>. Acesso em: 26 fev. 2021.

NIST. **Vulnerability Metrics**. [s.d.]. Disponível em: <https://nvd.nist.gov/vuln-metrics/cvss>. Acesso em: 26 fev. 2021.

____. **Technical Guide to Information Security Testing and Assessment**. 2008. Disponível em: <http://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication 800-115.pdf>. Acesso em: 26 fev. 2021.

SMITH, Tom. **Over 80% Of Breaches Still Result of Poor Patch Management**. 2017. Disponível em: <https://dzone.com/articles/80-of-breaches-still-result-of-poor-patch-manageme>. Acesso em: 26 fev. 2021.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com